

Scenario 3 Prompt

LLM-Integrated Account Recovery and Profile Management System

You are a cybersecurity threat modelling expert.

Perform a detailed threat modelling analysis of the following LLM-integrated account recovery and profile management system.

Follow the architecture exactly.

Do not introduce components that are not described.

System Name:

LLM-Integrated Account Recovery and Profile Management System

System Objective:

The system allows users to recover accounts and update profiles.

The AI assistant provides guidance only.

The AI assistant cannot:

- authenticate users
- approve recovery
- generate recovery tokens
- validate recovery tokens
- modify profiles

Trust Boundary 1:

External User Environment

Entity:

EE1 End User

User can:

- request account recovery
- submit recovery information
- ask account-related questions

All user inputs are untrusted.

Process P1:

Web Frontend Interface

Responsibilities:

- receives recovery requests
- receives profile update requests

- communicates with backend services
- displays results

Process P2:
Account Recovery Service

Role:

Recovery Authorization Authority

Responsibilities:

- verifies identity
- validates recovery requests
- generates recovery tokens
- validates recovery tokens
- controls recovery authorization

P2 is the only component responsible for recovery decisions.

Process P3:
Profile Management Service

Responsibilities:

- performs profile updates
- updates account information only after authorized recovery approval

Process P4:
AI Account Support Assistant

Responsibilities:

- answers account-related questions
- provides recovery guidance

Restrictions:

Cannot:

- authenticate users
- authorize recovery
- create tokens
- validate tokens
- modify profiles

Process P5:
LLM Integration Service

Responsibilities:

- creates sanitized prompts
- sends approved context
- receives external LLM responses

Data Store DS1:
User Database

Contains:

- account identity
- profile information
- recovery verification information

Data Store DS2:
Recovery Token Storage

Contains:

- active recovery tokens
- token metadata
- expiration information
- token consumption/invalidation state

External Entity EE2:
External LLM Provider

Outside application security control.

Receives only:

- sanitized prompts
- authorization-approved context

Never receives:

- recovery tokens
- identity verification secrets
- private account data

Important Security Assumptions:

1. Recovery authorization is performed only by P2.
2. Token lifecycle is controlled only by P2 and DS2.
3. AI provides assistance only.
4. AI cannot influence recovery decisions.
5. External LLM output is untrusted.
6. User-provided recovery information may be malicious.

Analyze threats related to:

- account takeover
- recovery token abuse
- token replay
- token leakage
- identity verification bypass
- privilege escalation
- unauthorized profile modification
- prompt injection
- sensitive information disclosure

- insecure output handling
- excessive AI agency
- external LLM risks

For each threat provide:

- Threat ID
- Threat name
- STRIDE category
- Affected component/data flow
- Attack scenario
- Impact
- Severity
- Likelihood
- Mitigation
- OWASP LLM Top 10 mapping